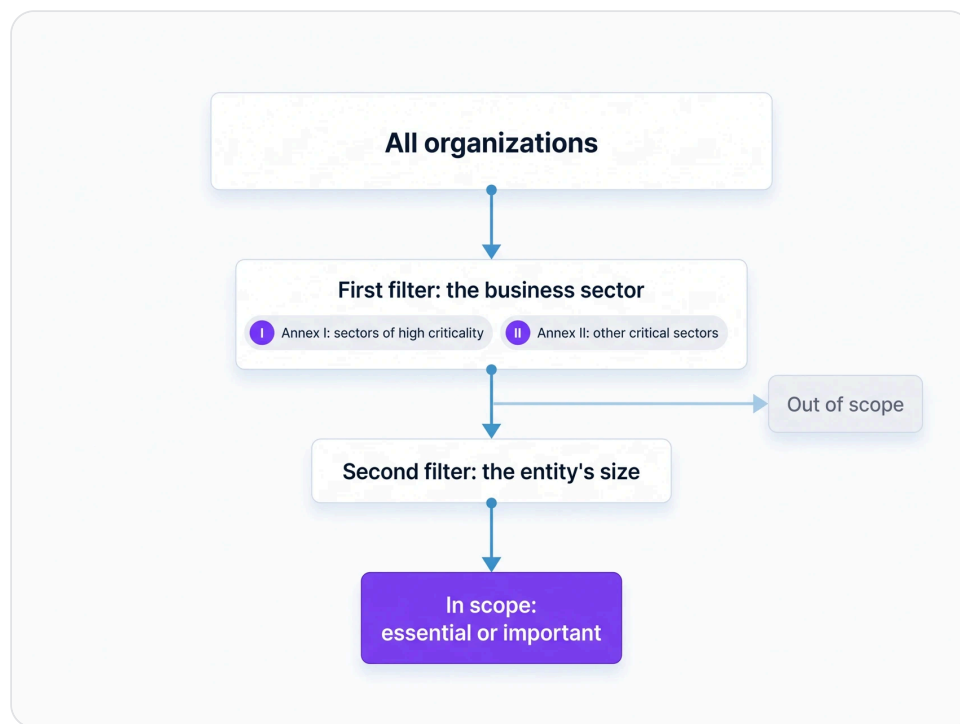


The CISO's briefing: NIS2 applicability

The question senior management will put to the Group CISO (RSSI Groupe) this week



Applicability is read through two cumulative filters, sector then size, and never measures the actual level of security.

Session objectives

By the end of this sequence:

- **Explain** what the NIS 2 directive is, where it comes from and what it changes compared with NIS 1
- **Distinguish** an essential entity from an important entity, and state what this distinction changes in concrete terms
- **Apply** the applicability criteria (sector of activity, size) to the four subsidiaries of the MERIDIAN group
- **Assess** the actual state of the French transposition and draw from it an honest answer for senior management
- **Relate** the NIS 2 registration obligation to the mapping built in session 2

Prerequisites

- The mapping of the MERIDIAN group built in session 2: business assets, supporting assets and DICT needs for each subsidiary. It is this morning's working material.

- The regulatory context of the subsidiaries set out in session 1: Santé (GDPR, HDS), Logistique (NIS 2), Éducation (GDPR), Territoires (NIS 2, RGS).
- The three levels of governance and the CISO's posture towards decision-makers, covered in session 1.

What to know before the exercise

This briefing sets out the three notions needed, and nothing more: the rest of the regulatory landscape will come in this morning's lecture.

First, the problem the directive was designed to address. For years, European cyber regulation covered only a handful of actors: the first NIS directive, adopted in July 2016 and transposed in France in 2018, targeted, according to ANSSI, the major actors of ten strategic sectors, that is, a few hundred French entities. The result: a mid-sized hospital, a regional logistics operator, a platform serving local authorities flew under the radar, when they are precisely the ones attackers strike. In its Panorama de la cybermenace (cyber threat overview) published in 2026, ANSSI counts 1 366 incidents brought to its attention over the year 2025, with ministries and local authorities accounting for 24 % of them. The threat does not sort its victims by regulatory status.

The NIS 2 directive, then, is the European answer to this coverage gap: Directive (EU) 2022/2555 of 14 December 2022, which succeeds NIS 1 and massively extends the range of organizations subject to cybersecurity obligations. A directive, to be borne in mind from the outset, is not a regulation: it sets a result to be achieved and leaves each Member State to transpose it into its national law. This legal detail will become the heart of the answer to senior management. According to ANSSI, several thousand entities spread across 18 sectors of activity will be concerned in France, and around 600 different types of entities, from public administrations to CAC40 groups.

The applicability criteria answer the question "am I in scope?". The directive's logic comes down to two cumulative filters. First filter, the sector: Annex I lists the "sectors of high criticality" (energy, transport, health, water, digital infrastructure, public administration, space, banking, among others), Annex II the "other critical sectors" (postal and courier services, waste management, manufacturing, digital providers, research, among others). Second filter, size: the directive targets medium-sized enterprises and above. What these criteria do not do: they say nothing about the actual level of security. An entity can be in scope and well protected, out of scope and vulnerable. Applicability triggers obligations, it measures nothing.

Essential and important entities are the directive's proportionality mechanism. Rather than imposing the same constraints on a national energy operator and on a mid-sized provider, NIS 2 creates two categories. The thresholds published by ANSSI on MonEspaceNIS2: essential entities are those which employ at least 250 people, or whose annual revenue exceeds 50 million euros and annual balance-sheet total 43 million euros, in a sector of high criticality; important entities are those which, without being essential, employ at least 50 people or exceed 10 million euros of revenue and balance-sheet total. The category changes two very concrete things. Supervision: the directive provides, for essential entities, a full supervisory regime, both ex ante and ex post, whereas important entities are supervised only after the fact, upon a report or an incident. And the sanction ceiling: the NIS 2 directive provides for financial penalties of up to 2 % of worldwide turnover for essential entities and 1.4 % for important entities. The limit of this neat mechanism: it rests on special cases and exceptions (certain digital providers are essential whatever their size, States keep room for choices), and this is why the reasoning always goes entity by entity, never in a single sentence.

Essential entity

Ex ante and ex post supervision

Fines up to **2** % of worldwide turnover

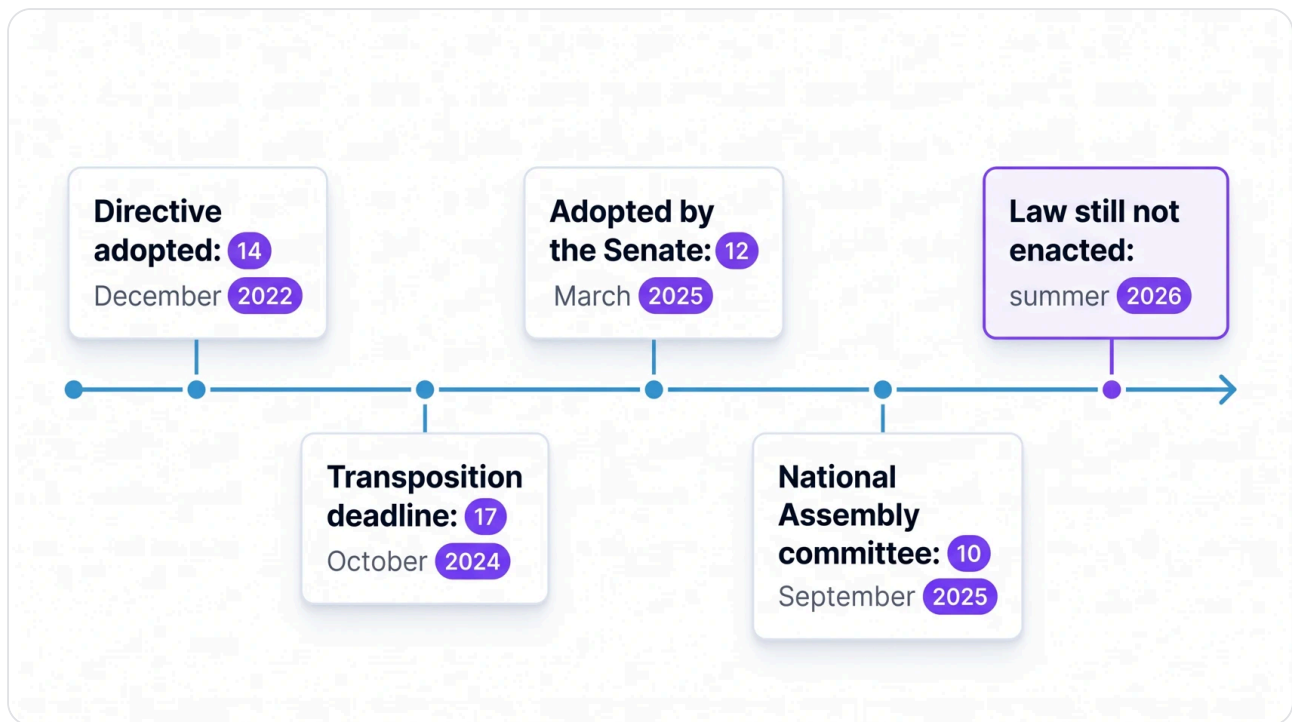
Important entity

Ex post supervision only

Fines up to **1.4** % of worldwide turnover

What the category changes in concrete terms: the intensity of supervision and the ceiling of the financial penalty.

One last thing before the exercise, and it is a trap many professionals fall into: **being within the scope of the directive does not mean being subject to French obligations today**. The directive set Member States a transposition deadline of 17 October 2024. France has missed it: the bill known as « Résilience » ("Resilience"), which transposes NIS 2, was adopted by the Senate on 12 March 2025, passed by the special committee of the National Assembly on 10 September 2025, and had still not been promulgated as of the summer of 2026. ANSSI states it in black and white: NIS 2 will enter into force in France once the law, its decrees and its orders have been promulgated. In the meantime, the agency invites future regulated entities to prepare, and provides an online applicability test and pre-registration on MonEspaceNIS2. A CISO who answers "we'll see when the law comes out" and a CISO who answers "we are already compliant" are both wrong. The case study builds the third answer.



The directive has been European law since late 2022, but the French transposition law had still not been promulgated as of the summer of 2026.

Method reflex: to determine applicability, always separate what the European text says (stable, published, enforceable) from what national law says (here: still under construction). An answer that mixes the two levels is wrong even when every piece of it is true.

Case study: is the MERIDIAN group concerned, subsidiary by subsidiary?

Scenario and problem statement

Monday morning, 8:40 a.m. The Chief Executive Officer of the MERIDIAN group catches the Group CISO in passing: "Over the weekend I read an article about the Résilience law and the fifteen thousand companies it covers. Are we among them? Apparently executives are personally liable. I want an answer at Thursday's Executive Committee." She is already gone.

The Group CISO has the mapping built in session 2 (business assets, supporting assets, DICT needs of the four subsidiaries) and the group's figures: MERIDIAN Santé (healthcare subsidiary), 3 200 employees and 4 care facilities; MERIDIAN Logistique, 2 800 employees and 6 warehouses, with a freight tracking and freight management business; MERIDIAN Éducation, 900 employees and 45 000 user accounts on its learning portal; MERIDIAN Territoires, 650 employees, operating a citizen services platform for some thirty client local authorities.

This morning's task: prepare the answer to be delivered on Thursday. Not a legal essay, a reasoned characterization, subsidiary by subsidiary, with what it implies.

Guided questions

1. **Classify** each subsidiary against the first filter, the sector: for each one, state the candidate annex (I, II, or outside the annexes) and the closest sector heading. For MERIDIAN Logistique, find TWO possible readings and keep both at this stage (hint: what distinguishes a "transport" activity from a "courier" activity in what the subsidiary actually does?).

.....
2. **Apply** the second filter, size: for each subsidiary retained in question 1, state whether it crosses the essential entities threshold or the important entities threshold, citing the criterion used.

.....
3. **Characterize** each subsidiary provisionally: essential, important, out of scope, or "depends on a choice still open". Each characterization takes one sentence of justification.

.....
4. **Draft** the three sentences to deliver to the Chief Executive Officer on Thursday in answer to "are we among them?", factoring in the actual state of the French transposition. Constraint: none of the three sentences may be proven wrong if the law is promulgated within six months.

.....
5. **Relate** this characterization to the session 2 mapping: what will Article 3 of the directive require the group to communicate to the national authority, and why is the group already ahead on this point?

.....

Working method

Work subsidiary by subsidiary, in the order Santé, Logistique, Territoires, Éducation: this is the order of increasing difficulty of the reasoning, not the order of the organization chart. For each subsidiary, write down first the fact (actual sector of activity, headcount), then the rule (annex, threshold), then the conclusion: this is the three-step reasoning expected at the session 6 oral, and it is exactly how a lawyer reasons. Refrain from concluding "yes" or "no" when the text does not support a conclusion: being able to say "it depends on a choice France has not yet made" is a skill, not an admission of weakness. Allow 20 minutes for questions 1 to 3, 10 minutes for questions 4 and 5.

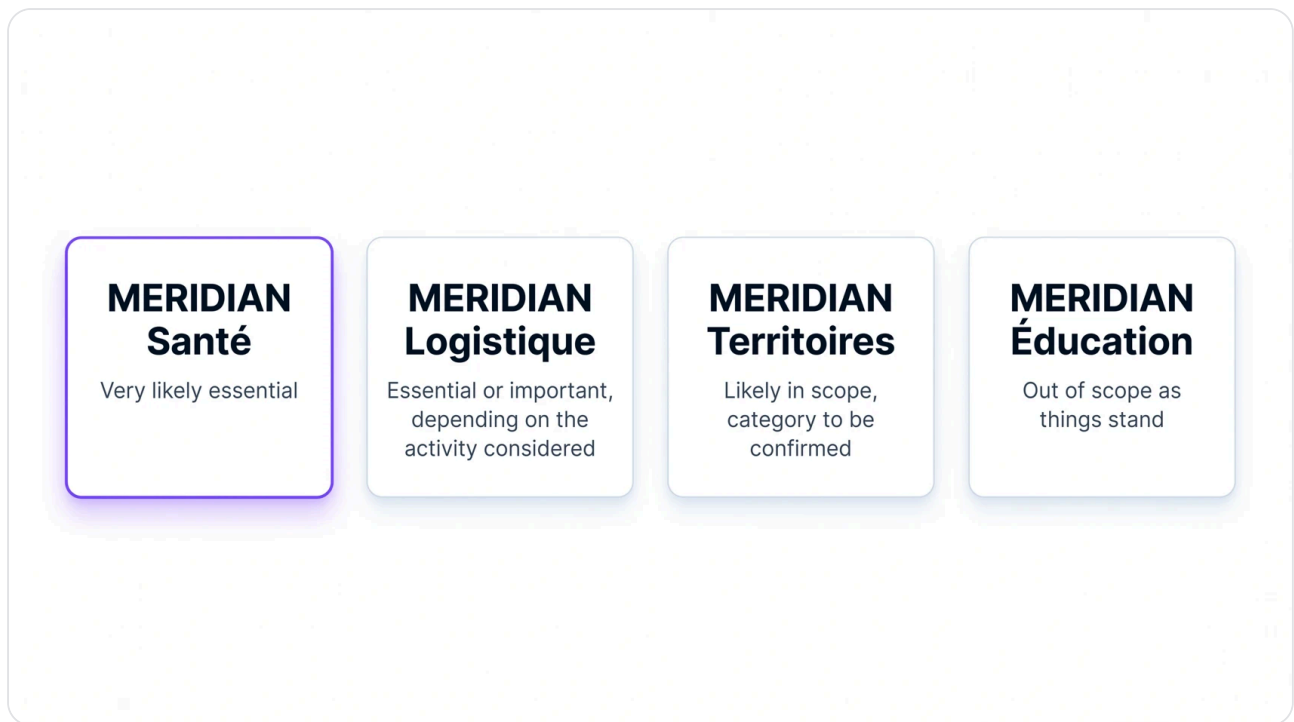
Answer keys and assessment criteria

Reasoned answer key, question by question

Question 1, the sector filter. MERIDIAN Santé operates care facilities: this is the "Health" sector of Annex I, a sector of high criticality, and the most solid reading of the four. MERIDIAN Logistique is the textbook case the exercise was designed around: looking at its fleet and its flows, its activity falls under "Transport" (Annex I); looking at its parcel preparation and delivery business, it falls under "Postal and courier services" (Annex II). Both readings are defensible on the available elements, and they do not lead to the same category: this is precisely why both are kept, and why the subsidiary's actual revenue breakdown will be obtained before deciding. MERIDIAN Territoires operates local public services for local authorities: the candidate sector is "Public administration" (Annex I), but Article 2 of the directive leaves each Member State free to decide whether or not to apply the text to public administration entities at local level; the subsidiary itself is a private provider, which adds a second uncertainty, that of whether it will be caught directly or through its clients. MERIDIAN Éducation, finally, matches no sector of the annexes: education does not appear there, and the only possible way in would be "Research" (Annex II) if the subsidiary carried out research, which is not the case in this file. It is the counter-example: a subsidiary can be the most exposed in the group (45 000 accounts, members of the public on its premises) and still sit outside the scope of a text. Applicability does not measure risk.

Question 2, the size filter. Reminder of the thresholds published by ANSSI: at least 250 employees, or more than 50 million euros of annual revenue and 43 million euros of balance-sheet total, for the essential entities of a sector of high criticality; at least 50 employees or 10 million euros for important entities. Santé, 3 200 employees, is far above the essential entities headcount threshold. Logistique, 2 800 employees, is above it too. Territoires, 650 employees, likewise. Éducation, 900 employees, would cross every size threshold, but size never makes up for a sector absent from the annexes: the sector filter applies first, the size filter second.

Question 3, the provisional characterization. Santé: essential entity (Annex I sector, headcount above the essential entities threshold), the only characterization the CISO can announce with a high level of confidence. Logistique: essential if its activity is characterized as "Transport" (Annex I), important if it is characterized as "Postal and courier services" (Annex II, where entities are important unless designated otherwise); the category, and with it the supervisory regime and the sanction ceiling, depends on a characterization of the activity that must be properly investigated. Territoires: hangs on a double choice, France's choice regarding local public administrations (the bill adopted in the Senate proposes to include regions, departments, inter-municipal authorities and large municipalities) and the choice regarding the status of a private operator of local public services; it is treated as "probably in scope, category to be confirmed" and the final text is monitored. Éducation: out of scope as things stand, which exempts it from nothing in security terms, GDPR first and foremost.



Four subsidiaries, four distinct verdicts, and only one can be stated with a high level of confidence.

Question 4, the three sentences for Thursday. An example of an answer that holds: "Yes, the group is concerned: at least one subsidiary, Santé, will very probably be an essential entity, and Logistique will be at the very least an important entity. No, no NIS 2 obligation applies to us today: the French transposition law, adopted in the Senate in March 2025, has not yet been promulgated, and the obligations will arrive with its decrees. We are putting this time to good use: our mapping is ready, and I propose to put the choice of our security framework on the agenda; that is the subject of my note for Thursday." Three sentences, three levels: the European fact, the French fact, the decision requested. What these sentences do not say: no compliance date promised, no sanction figure brandished to frighten. Fear is a poor budget.

Question 5, the bridge to the mapping. Article 3 of the directive requires entities to communicate their identification information to the authorities: the name of the entity, "the address and up-to-date contact details, including email addresses, IP ranges and telephone numbers", and the sector concerned. Read that list again: it is an extract of a mapping. A group which, like MERIDIAN since session 2, keeps its business views and its inventories up to date produces this registration file in hours, not weeks. This is the argument that turns session 2 into a profitable investment in the eyes of an Executive Committee: the mapping was not an exercise in style, it was the silent prerequisite of the compliance to come.

Assessment matrix

CRITERION	INSUFFICIENT	EXPECTED	EXCELLENT
Sector filter	One annex per subsidiary, without justification	All 4 subsidiaries assigned, with justification, including the 2 readings for Logistique	Same, plus the point to investigate to settle Logistique (actual breakdown of the activity)
Size filter	Thresholds recited without being applied	Thresholds applied to the headcount of each retained subsidiary	Same, plus the ordering rule: sector first, size second
Characterization	A single overall "yes/no" for the group	Four distinct characterizations, including at least one assumed "depends on an open choice"	Same, with what each category changes (supervision, sanctions)
Answer to the CEO	Alarmist or wait-and-see	Three sentences distinguishing European law from French law	Same, ending with a decision requested, not an observation
Mapping bridge	Absent	The registration obligation related to the session 2 views	Same, framed as a return on investment defended in committee